

Activo Amenaza Vulnerabilidad Riesgo Tratamiento Control Política Evidencia

Activo	Amenaza	Vulnerabilidad	Riesgo	Tratamiento	Control	Política	Evidencia
(✓) Clientes Servidores Switches Datos de Clientes Correo electrónico CRM ERP BD	(✓) Ciberdelincuencia Empleados inconfiables Competencia Desastres naturales	(✓) - Contraseñas Débiles - Desatención de racks - Falta de MFA - Falta de respaldos - Falta de actualización de software - Día cero (Zero Day) - Falta de segmentación de red - Falta de capacitación de empleados	(✓) - Compromiso de cuentas - Robo de info / datos	(✓) - Mitigar - Aceptar - Transferir - Evitar			

Nova Bank	ISO 27001 vs 27002
Reglas	Playbook Defensivo
- Política - Estandar - Procedimiento - Instructivo	¿Qué? ¿Cómo?

A5 ¿Quién manda y cuales son las reglas

A6 Roles y Responsab

A7 ¿Que hacemos con las personas

A8 ¿Que tenemos que proteger

A9 ¿Quien puede entrar?

A10 ¿Como protegemos la info

A11 Como protegemos físicamente

A12 Como operamos de forma segura

A13 Como nos comunicamos

A14 Como construimos sistemas

A15 Que hacemos con los terceros

A16 Que hacemos cuando algo falla

A17 Como sobrevivimos

A18 Que debemos cumplir

FASE 1 8:03 AM - ¿Algo ocurrió?

Activo(s) que debemos proteger	Clientes, servidores, switches, datos de clientes, correos, BD
Amenaza	Atacantes no identificados, backdoors, empleados descontentos
Vulnerabilidades posibles	Malas configuraciones, contraseñas débiles, Zero Day, MFA, Actualizaciones de software
Riesgo formulado	Compromiso o robo de datos, escalación de privilegios
Impacto principal	Daño a la reputación, daño a terceros, monetaria
Tratamiento propuesto	Mitigar
Primera acción que tomaría el equipo	Aislar la cuenta, revisando los logs, quitar accesos

Angel - Auditor
Leo - CISO
Esau - Analista
Carlos - Dueño
Israel - Relator

FASE 2 Del Riesgo al Control

Riesgo / Problema	Dominio o control ISO 27002	¿Que exigiria el control?	Preventivo, detectivo o correctivo?
Robo de datos	A8, A16	Autenticación, contraseñas robustas	Detectivo, preventivo
Escalación de privilegios	A9	Hardening, segmentación	Preventivo

¿Porque eligieron estos controles y no otros?

Son los mas cercanos a la corrección y prevención de los problemas definidos

FASE 3

P Los accesos corporativos deberán utilizar mecanismos de autenticación aprobados por la org

E MFA será obligatorio para accesos privilegiados y remotos

PR Ingrese al portal, seleccione Seguridad y registre el segundo factor

G Se recomienda utilizar un gestor de contraseñas aprobado

P Los accesos deberán revisarse periódicamente conforme al nivel de riesgo

3: Procedimiento debido a que nos indica los pasos que deben llevarse a cabo

5: Indica lo que esperamos y el porque

FASE 4

3 problemas

- Desarrollador publica un secreto
- Usuario abre un phishing
- Nadie sabe a quien reportar un incidente

#1

Problema Desarrollador publica un secreto

Activo afectados Información

Riesgo Compromete la información

Tratamiento Aceptar

Control ISO
27002 A12, A13

Politica o
regla necesaria Política de minimo privilegio, capacitaciones periodicas sobre CIA
escaneos estaticos

Evidencia que
solicitaria un auditor Control de trafico interno

2

Problema Usuario abre un phishing

Activo afectados Cuenta del empleado afectado

Riesgo Movimiento lateral

Tratamiento Mitigar

Control ISO
27002 A9, A7, A8

Politica o
regla necesaria Cursos de concientizacion, segmentacion de red

Evidencia que
solicitaria un auditor Revisión de perfiles, control de accesos

3

Problema Nadie sabe a quien reportar un incidente

Activo afectados Información / Incidente a reportar

Riesgo No se atiende a tiempo, o que no se atiende

Tratamiento Mitigar

Control ISO
27002 A13, A16

Politica o
regla necesaria Definir roles y responsabilidades, procedimiento en caso de incidente

Evidencia que
solicitaria un auditor Reporte de hechos, documento de la politica

FASE 5 - El proveedor

1.- ¿De quien es el riesgo

Ambos

2.- ¿Que requisitos de seguridad debieron establecerse con el proveedor

FASE 6 Ya es un incidente

se confirma que info fue descargada. El equipo debe pasar de prevención a respuesta

Etapas	Decisión / Acción de NOVA BANK	Evidencia que debe conservarse
Identificación	Identificación de logs	Registros
Contención	Aislar la BD	Registro de permisos de la BD
Erradicación	Se elimina el acceso del proveedor externo y se crea un nuevo perfil con la configuración necesaria	Evidencia de la eliminación y creación del nuevo usuario
Recuperación	Evaluación del daño, restablecer los servicios	Presentación del respaldo, pruebas
Comunicación / Escalamiento	Comunicar a todos los empleados, proveedores, clientes sobre lo sucedido	Presentar pruebas del lanzamiento del comunicado mediante red corporativa
Lecciones aprendidas	Revisión periódica de configuración y sistemas de seguridad	Presentar informes de actualizaciones de seguridad postincidente

FASE 7

Nombre de la política	Gestión de Incidentes
Propósito	Definir como actuar ante un incidente de seguridad para detectar, contener y recuperar el daño
Alcance	Aplica para todo el personal
Reglas obligatorias	1.- Todo incidente o sospecha se reportará de inmediato al equipo de seguridad 2.- Se debe contener el problema y cortar el acceso no autorizado antes de restaurar sistemas 3.- Queda prohibido ocultar, minimizar o borrar evidencias de un incidente 4.- Después de cada incidente se creará un registro detallado de lo sucedido
Roles y responsabilidades	Dirección aprueba la política Quien ejecuta es el departamento de TI El jefe de departamento supervisa y cumple Todo el personal debe cumplir

Excepciones

Evidencia de cumplimiento

Revisión

NOVA Bank termina un contrato de mantenimiento, 6 meses después 2 cuentas del proveedor pueden conectarse

El admin afirma que hay respaldos reales, durante un ataque de ransomware descubre que nadie en 2 años había probado una restauración en 2 años

Problema/Riesgo Riesgo acceso no autorizado, robo de datos o sabotaje, usuarios externos

Control ISO 27002 A15 Que hacemos con los proveedores 15.2.1 Monitoreo y revisión de los servicios de proveedores

Categoría Administrativo

Tipo / Función Detectivo

Justificación Al finalizar el contrato se deben de dar de baja las cuentas del proveedor

Segunda opción control A15 Que hacemos con los proveedores 15.2.1 Monitoreo y revisión de los servicios de proveedores
Admin / Detectivo, revisar periódicamente que los accesos de terceros sigan vigentes solo si el contrato lo permite

Problema/Riesgo Ante un incidente de seguridad la empresa podría perder datos sin posibilidad de recuperarlos al no tener respaldos comprobados en los últimos 2 años

Control ISO 27002 A12.3.1 Respallos de Información

Categoría Administrativo Técnico / Lógico

Tipo / Función Detectivo

Justificación Al comprobar que no hay respaldos de datos podríamos perder la información ante un incidente

Segunda opción control A18.2.2 Cumplimiento de las políticas y normas de seguridad
Administrativo / Detectivo

Una revisión interna podría comprobar si en realidad se realizaban respaldos de seguridad